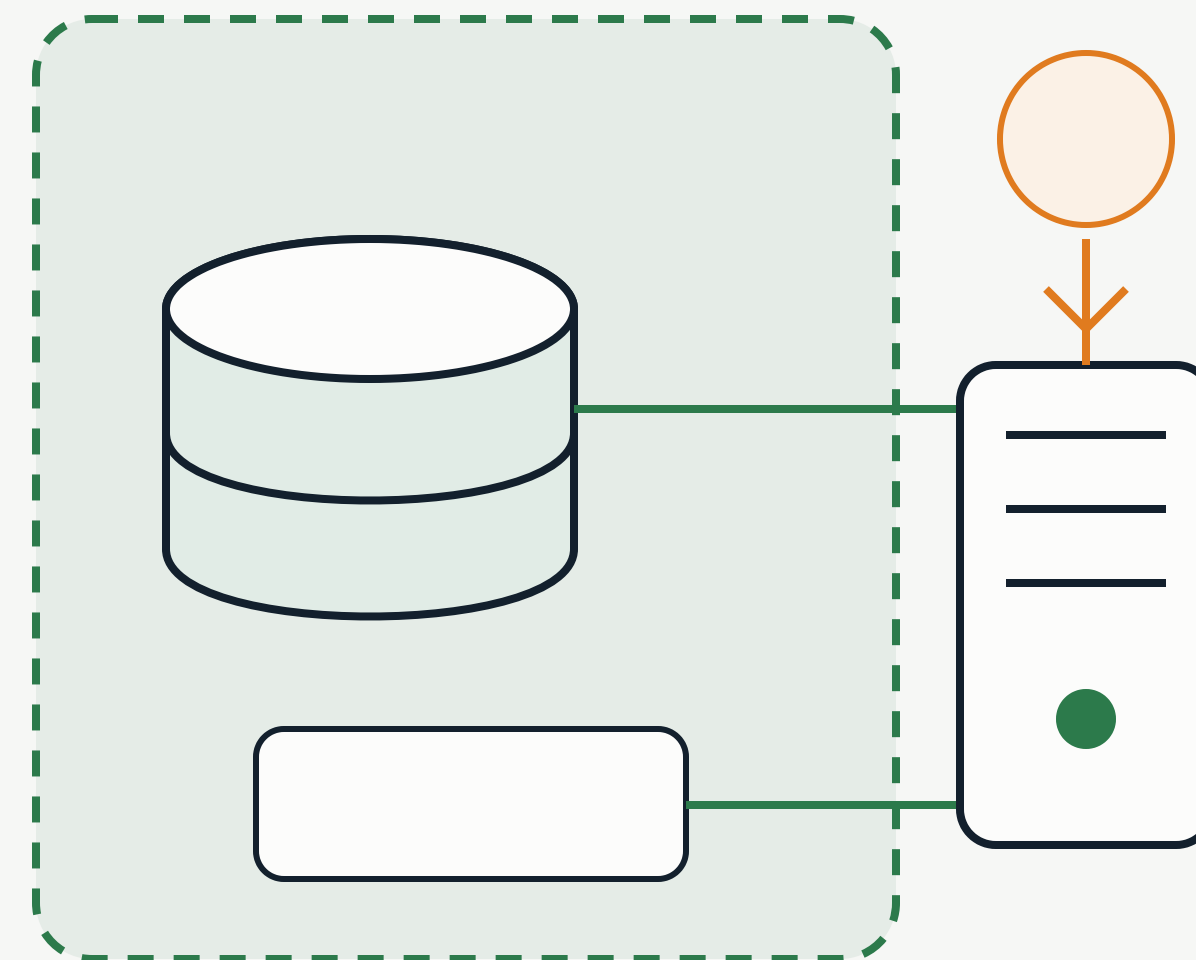


Имовина, границе поверења и threat modeling

Идентификација имовине, токова података и граница
поверења



Садржај презентације

01

Имовина и токови

Власништво, утицај, инвентар и токови (04–08).

02

Границе поверења

Архитектонска скица, претпоставке и модел (09–14).

03

Претње и контроле

Сценарио, ризик, захтев и серверска провера (15–21).

04

Доказ и одржавање

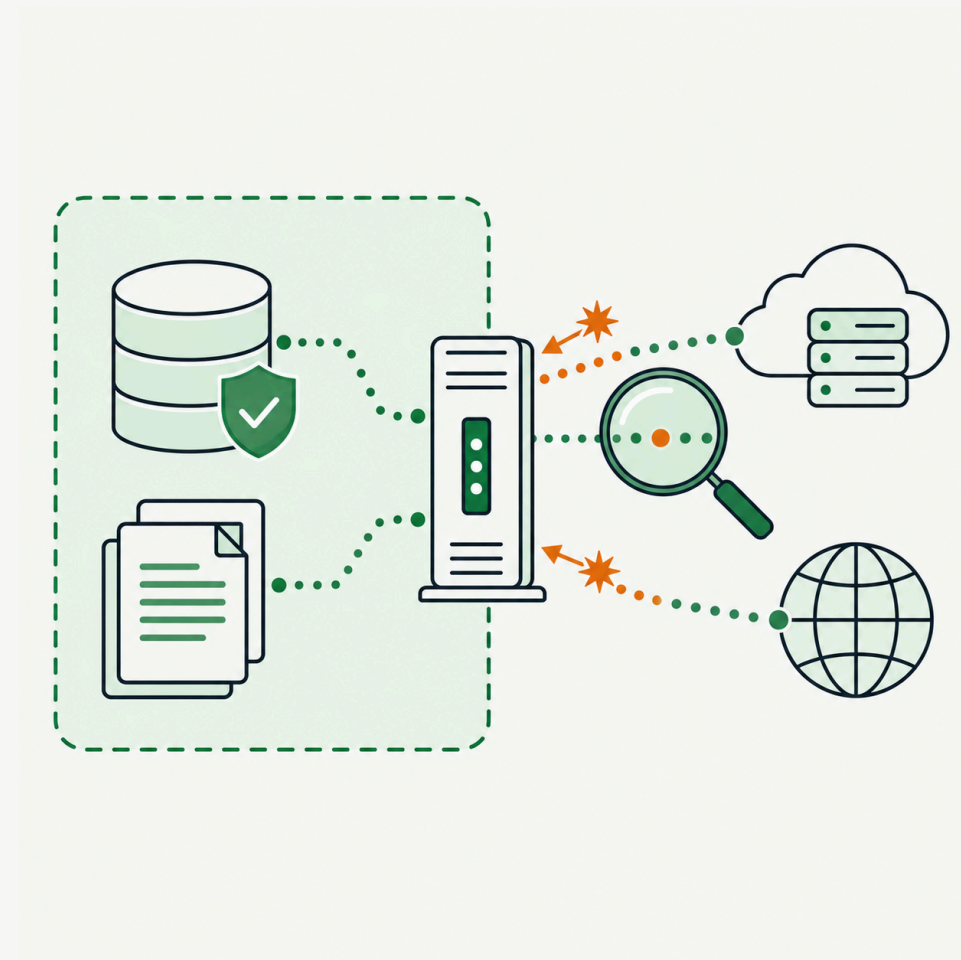
Код, тест, запис и ажурирање модела (22–30).

Увод

Шта штитимо и зашто је модел претњи потребан (03).

Имовина и границе поверења

Анализа претњи полази од вредне имовине, токова података, граница поверења и последица могућег нарушавања.



ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Безбедносна одлука полази од вредне имовине, тока података и граница поверења. На тој основи тим идентификује релевантну претњу и бира контролу примерену конкретном ризику.

ЗНАЧАЈ

Значај за безбедност система

Моделовање претњи повезује техничку структуру система са пословним последицама и омогућава рану проверу безбедносних претпоставки.

КРИТЕРИЈУМ ПРОВЕРЕ

Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

01

ПРВИ ДЕО

Имовина и токови

Разумети вредност податка пре него што се изабере контрола.

власник

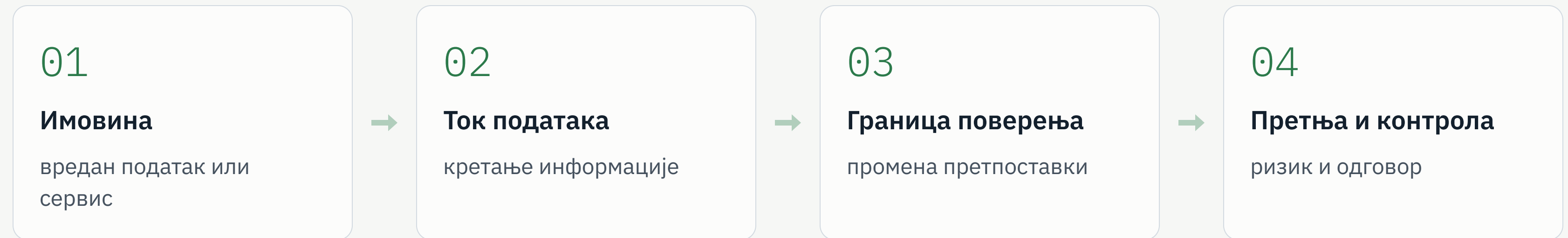
пословни утицај

животни циклус

инвентар

Основни појмови

Имовина, ток података, граница поверења и претња одређују обим анализе и избор контроле.



ЗАКЉУЧАК

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.

Имовина

вредан податак или сервис

01 **Имовина има власника, значај за пословање и животни циклус.**

Питање: који улаз покреће ову одлуку?

02 **Утицај на пословање је оцена имовине, а не особина појединачне претње.**

Питање: која граница мора бити видљива?

03 **Инвентар је користан тек када се оцена имовине користи у процени ризика.**

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Која имовина у вашој целини има највећи пословни утицај и ко је њен власник?

Ток података

кретање информације

01 Ток података показује одакле информација долази, куда иде и ко је успут обрађује.

Питање: који улаз покреће ову одлуку?

02 Сваки ток је везан за имовину коју преноси, па наслеђује њен значај.

Питање: која граница мора бити видљива?

03 Дијаграм тока се ажурира када се промени интеграција, извоз или место чувања.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ток осетљивог податка у вашем систему има највише учесника?

Инвентар који води до одлуке

Мали запис је користан када повезује власника, вредност и стварни ток.

Имовина	Власник и вредност	Ток и животни циклус
Пословни записи	Пословни тим, поверљивост и исправност	Креирање → API → база → извоз
Сервисни идентитет	Власник интеграције, дозвољене радње	Издавање → употреба → опозив
Кључ потписа	Одговорни тим, веродостојност поруке	Чување → ротација → уништавање

Илустративни пример

Утицај припада имовини. Конкретна претња објашњава како та вредност може бити нарушена.

02

ДРУГИ ДЕО

Границе поверења

Уцртати места на којима се мењају претпоставке о идентитету и подацима.

DFD

спољни улаз

складиште

серверска провера

Граница поверења

промена претпоставки

01 Граница поверења је место где престаје да важи претпоставка о пореклу и исправности податка.

Питање: који улаз покреће ову одлуку?

02 Ток који прелази границу поверења носи већи ризик и тражи експлицитну проверу.

Питање: која граница мора бити видљива?

03 За сваку границу се бележи која претпоставка више не важи и која је контрола замењује.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ток осетљивог податка прелази границу поверења и на ком месту се претпоставка мења?

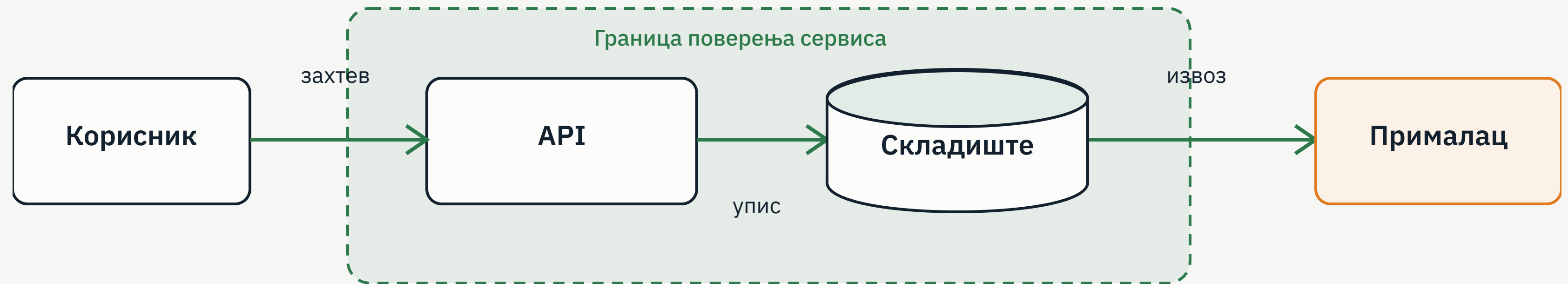
Имовина, рањивост и претња

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Појам	Значење	Питање за анализу
Имовина	Оно чија вредност захтева заштиту.	Шта губимо ако је угрожена?
Рањивост	Слабост коју је могуће искористити.	Где систем нема довољну заштиту?
Претња	Могући узрок нежељеног исхода.	Ко или шта може активирати слабост?
Ризик	Комбинација вероватноће и последице.	Шта прво треба умањити?

Шта показује једноставан DFD

Компоненте, податак и граница чине основу разговора о претњама.



Илустративни пример • стрелице показују податак и смер, испрекидана линија промену претпоставки.

Читање архитектонске скице кроз безбедност

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

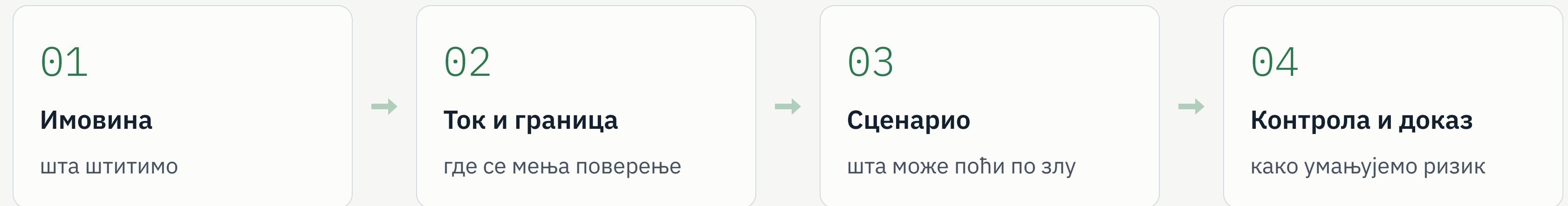
Читање архитектонске скице кроз безбедност

Архитектонска скица добија безбедносну вредност када се преко компоненти уцртају подаци, идентитети и границе поверења. Није потребно цртати сваку класу. Довољно је показати делове кроз које пролази вредна информација и одлуке које мењају њен статус.

- 01 Означити улазе које контролише корисник или спољашњи сервис.
- 02 Означити место где се идентитет или дозвола поново проверавају.
- 03 Означити складишта, кључеве и интеграције које мењају последицу инцидента.
- 04 Уз сваку границу записати једну реалну претпоставку која може бити погрешна.

Поступак моделовања претњи

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

03

ТРЕЋИ ДЕО

Претње и контроле

Од конкретног сценарија до провере која умањује ризик.

актер

сценарио

ризик

контрола

преостали ризик

Претња и контрола

ризик и одговор

01 Претња је конкретан сценарио: ко, преко ког тока, шта може да наруши.

Питање: који улаз покреће ову одлуку?

02 У овом моделу ризик је производ вероватноће и утицаја, праг из политике одређује шта се мора третирати.

Питање: која граница мора бити видљива?

03 Преостали ризик се бележи заједно са контролом и њеним ограничењима.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који сценарио у вашем моделу прелази праг третмана и која контрола на њега одговара?

Четири питања за радни модел

OWASP организује моделовање као поновљив циклус ових питања.

-
- 01 На чему радимо?**
Скица система, имовина, токови и границе.
 - 02 Шта може поћи по злу?**
Конкретан актер, улаз и нежељена последица.
 - 03 Шта ћемо предузети?**
Контрола која одговара одабраном сценарију.
 - 04 Да ли је довољно?**
Провера контроле и јасно записан преостали ризик.
-

Модел пре контроле

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01 **Имовина има власника, значај и животни циклус.**

Јасно правило

02 **Интеграција спољне компоненте не представља основ за доделу поверења.**

Проверљива примена

03 **Претња постаје корисна када води до захтева, контроле и начина провере.**

Видљив доказ

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Архитектурни цртеж постаје радни алат када уз сваку важну границу наведе податке, актере и претпоставке. Тим затим бира мали број реалних сценарија злоупотребе и проверава их тестом или прегледом дизајна.

01 Дефинисана одлука и њена граница.

02 Серверска имплементација провере.

03 Позитиван и негативан доказ.

Случај: извоз из интерног система

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

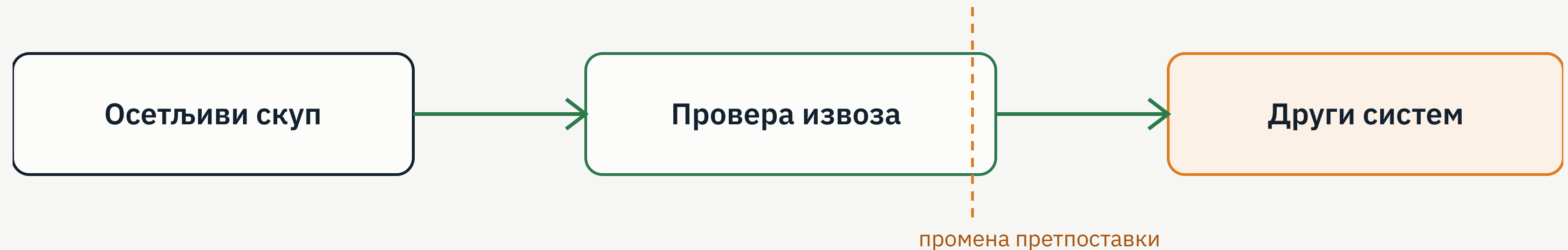
СЦЕНАРИО

Интерни сервис припрема извоз осетљивих података за други систем. Тим га доживљава као безбедан јер је сервис „унутра“, али сам прелазак података у други систем мења претпоставке. Потребно је знати који податак путује, ко прима податак, шта може поћи по злу и како систем спречава или бар открива нежељен исход.

- 01 **Имовина обухвата базу података, налоге, кључеве, сервисне идентитете, конфигурацију и пословне записе.**
- 02 **Граница поверења може бити API позив, ред порука, административни интерфејс или извоз у датотеку.**
- 03 **Модел претњи обухвата ограничен број реалних сценарија, одговарајуће контроле и начине њихове провере.**

„Унутра” није довољна претпоставка

Одлука остаје на сервису који предаје податак преко границе.



Илустративни сценарио

Погрешан прималац или преширок скуп нарушава поверљивост. Контрола проверава примаоца и обим, а тест покушава недозвољени извоз.

04

ЧЕТВРТИ ДЕО

Доказ и одржавање

Одлука се доказује кодом, тестом и записом, а модел прати промене система.

политика

тест

ревизиони запис

ажурирање

Прелазак границе поверења повећава ризик

C# • изворни пример

```
1  public ThreatAssessment Assess(  
2      ThreatScenario scenario)  
3  {  
4      var score = Score(scenario);  
5      return new ThreatAssessment(  
6          scenario, score,  
7          score >= policy.TreatmentThreshold);  
8  }  
9  private int Score(ThreatScenario scenario)  
10 {  
11     var exposure =  
12         scenario.Flow.CrossesTrustBoundary  
13         ? policy.TrustBoundaryMultiplier : 1;  
14     return scenario.Likelihood  
15         * scenario.Flow.Asset.BusinessImpact  
16         * exposure;  
17 }
```

ТУМАЧЕЊЕ

У овом примеру ризик је производ вероватноће и утицаја на имовину, прелазак границе поверења га увећава.

БЕЗБЕДНОСНА ГРАНИЦА

Праг третмана долази из политике, па се одлука може тестирати и образложити.

Тест доказује утицај границе поверења

У овом тестном примеру множилац политике је 2.

C# • изворни пример

```
1 [Test]
2 public void
3     Assess_WhenFlowCrossesTrustBoundary_DoublesTheScore()
4 {
5     var assessment = _calculator.Assess(
6         Scenarios.Create(3, 5, crossesTrustBoundary: true));
7     Assert.That(assessment.RiskScore, Is.EqualTo(30));
8 }
```

ДОКАЗ

Вероватноћа 3 и утицај 5 дају 15, а уз прелазак границе поверења 30.

ОЧЕКИВАНИ ИСХОД

Тест мења једну чињеницу и очекује тачно одређен резултат ризика.

Садржај безбедносног записа

Контекст одлуке се чува без тајни и сувишних личних података.

JSON • илустративни запис

```
1  {  
2    "asset": "payment-ledger",  
3    "trustBoundary": "public-api",  
4    "threat": "forged-command",  
5    "control": "signature-validation",  
6    "test": "reject-invalid-signature",  
7    "residualRisk": "stolen-valid-key"  
8  }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог
Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, токен, тајна и сувишан садржај
Траг не сме да постане нови извор цурења или збирка непотребних података.

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01 **Инвентар који постоји само ради евиденције, без власништва и значаја.**
Нема јасног власника одлуке.

02 **Општи каталог претњи који није повезан са стварним системом.**
Не постоји негативан сценарио.

03 **Контрола изабрана пре разумевања ризика који треба да смањи.**
Доказ не показује стварни исход.

Одржавање модела претњи

Модел се ажурира када се промене имовина, ток података, граница поверења или претпоставке система.

ОБРАЗЛОЖЕЊЕ

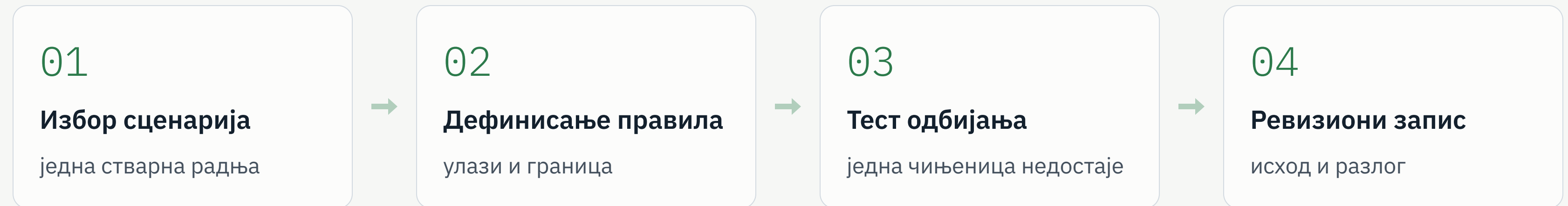
Одржавање модела претњи

Модел претњи ажурира се када систем добије нови улаз, интеграцију, начин чувања података или привилеговану радњу. Значајна архитектонска промена захтева поновну проверу постојећих претпоставки.

- 01 Дијаграм се ажурира када ток података или граница поверења стварно промени понашање система.
- 02 За одабрани сценарио постоји веза до контроле, теста или прегледа који га проверава.
- 03 Преостали ризик бележи се јасно, заједно са прихваћеним ограничењима контроле.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.



ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Имовина, границе поверења и threat modeling“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.

01

Имовина

вредан податак или сервис

02

Ток података

кретање информације

03

Граница поверења

промена претпоставки

04

Претња и контрола

ризик и одговор

ПИТАЊЕ ЗА ПРОВЕРУ

Који ток осетљивог податка прелази границу поверења и на ком месту се претпоставка мења?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.

Модел претњи повезује вредност и доказ

Имовина → ток → граница → сценарио → контрола → провера

Најкориснији модел је довољно конкретан да промени захтев, серверску проверу или тест.

После промене система поново проверити претпоставке и преостали ризик.